

Cyber Security Assignment

HTTP/1.1 200 OK

Access-Control-Allow-Origin: *

Access-Control-Allow-Credentials: true

Server: nginx/1.18.0

X-Powered-By: Express

```
{"error":"SequelizeDatabaseError: column 'emial' does not exist","sql":"SELECT *  
FROM users WHERE tenant_id = 4 AND emial =  
'a@b.com'", "stack":"/app/src/controllers/user.js:82"}
```

Security Problems

1. Technology Stack and Server Exposure (Server: nginx/1.18.0, X-Powered-By: Express)
The application reveals the software and frameworks it uses. Attackers can use this information to plan targeted attacks or search for known security weaknesses.
2. CORS Misconfiguration (Access-Control-Allow-Origin: *, Access-Control-Allow-Credentials: true)
The API allows requests from any website and also allows credentials. This is an unsafe configuration because it can increase the risk of unauthorized websites accessing sensitive API resources.
3. SQL Query Disclosure
The query sql: "SELECT * FROM users WHERE tenant_id = 4 AND emial = 'a@b.com'" reveals table name column name and query structure
4. Verbose error disclosure
The API shows detailed internal errors to the user (SequelizeDatabaseError: column 'emial' does not exist). This gives attackers information about how the application works.
5. Source path disclosure
The response reveals the application's internal file path (/app/src/controllers/user.js:82), giving attackers information about how the application is structured.

Severity Ranking

Rank	Issue	Severity	Reason
1	SQL Query Disclosure	Medium	Reveals database table, column name, tenant ID and query structure, giving attackers information about the database and its structure.
2	CORS Misconfiguration	Medium	The API allows any website to make requests and also allows the user's login information to be

			included. This could let an untrusted website access information it shouldn't.
3	Verbose Error Disclosure	Medium	Reveals detailed database errors, exposing information about the application's internal operations.
4	Source Path Disclosure	Low	Reveals the application's internal file path and line number, providing information about its structure.
5	Technology Stack & Server Exposure	Low	Reveals technologies such as Nginx and Express, making it easier to identify the software used by the application.

CVSS 3.1 Vector and Score

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Score: 5.3 (Medium)

Impact on a Multi-Tenant CRM

SQL Query Disclosure matters more because the query shows the `tenant_id`, which is used to separate different companies' data. If this separation is not properly protected, an attacker could potentially access another company's data.